

Roles, Pages & Access

دليل الأدوار والصلاحيات — AIGP Transformation Portal

Prepared for the IT team · staging handover · July 2026

Roles, Pages & Access — دليل الأدوار والصلاحيات

A plain-language reference for IT: **who each role is, which pages they see, what they can do, and what the server lets them touch.** The authoritative sources in code are `prisma/seed.ts` (permission matrix), `lib/security/rbac.ts` (enforcement) and `lib/viewModel.ts` (page/menu scoping).

1. How access works (two layers)

1. **UI role** (`users.role` , one of `coord / path / deputy / ai / admin`) — decides which **screens, menus, cards and buttons** the user sees.
2. **Backend RBAC** (`user_roles` → `role_permissions` + entity/stream scopes) — every API call re-checks: valid session → permission code → entity/stream scope → action, and writes an `audit_logs` row. Hiding a button is UX only; the server check is what actually protects the data.

On first login the identity (UAE PASS / Workspace ONE / mock-dev) is mapped to a `users` row; the UI role and backend role are assigned from `role_assignment_rules` or the admin APIs. **All accounts for all entities are provisioned centrally by the system admin** — there is no self-service team setup.

2. Quick reference

UI role	Arabic	Backend code	Data scope	One-line job
coord	منسق المسار في الجهة	entity_coordinator	own entity + own stream(s) (incl. drafts)	Fills the stream inventory and distributes entries over دفعات الإطلاق
path	رئيس المسار	stream_owner	own stream, all entities	The ent1 approver — اعتماد / إعادة للتعديل / طلب تفاصيل
deputy	نائب رئيس المسار	stream_owner	own stream, all entities	Same review powers as the stream head
ai	اللجنة الوطنية (الرئيس + الأمانة العامة)	ai_committee	everything, approved entries only	National read-only oversight
admin	مشرف النظام	system_admin	global	Manages users, roles, the public site and inquiries

Legacy backend roles (entity_representative , entity_admin) remain seeded for compatibility but are **not part of the current flow** and hold no approval permissions.

Streams (3): (services) الخدمات الحكومية · (strategy) العمل الحكومي الاستراتيجي · (ops) العمليات والدعم المؤسسي (3).

Entry types (one per stream, enforced everywhere): عملية in ops · مهمة in strategy · خدمة in services . Statuses are exactly four: معتمد / للتعديل / قيد الاعتماد / مسودة (approved entries are locked).

3. Role by role

3.1 منسق المسار في الجهة — coord / entity_coordinator

Who: the working-level user inside a federal entity, responsible for one stream — or several: with more than one `user_stream_scopes` row, the sidebar's **قوائم الحصر** lists every assigned stream.

Pages (sidebar): - **قوائم الحصر** — one entry per assigned stream; each opens the stream's inventory table with the stream's own columns and filters (ops: **تصنيف العملية / القطاع / نوع عملية الدعم المؤسسي** (conditional) — strategy: **المحور / الأولوية** — services: **الدفعات** (الدفعات) — **دفعات الإطلاق** — one sub-page per assigned stream: the stream's batches (الدفعات) — **إرشادات استخدام المنصة** — the guided tour

Can do: add entries manually («إضافة يدوية») — in the services stream **الخدمة الفرعية** the **خدمة/الخدمة** come from the entity-scoped **دليل** (dropdowns) or via the per-stream Excel template («رفع ملف Excel» — incomplete rows import as «بيانات ناقصة» drafts); select drafts → «إرسال للاعتماد» / «إكمال وإرسال» (with the missing-fields popup); distribute entries over **دفعات** and set their dates; export reports.

Cannot: approve or reject; edit an approved (**معتمد**) entry; place an entry on another stream's batches; see other entities.

3.2 رئيس المسار ونائبه — path + deputy / stream_owner

Who: the national head (and deputy) of ONE stream, seeing that stream across **all** entities. Assigned by the system admin with the stream scope.

Pages (sidebar): - **دفعات الإطلاق** — the stream's batches (read-only; distribution and dates are the coordinator's responsibility) - **الجهات المشاركة** — participation per entity

Can do: **إضافية** entries — from the list row, the details drawer, or the notification. Every decision notifies the coordinator. Export.

Cannot: create or edit entries; return an entry after it is **معتمد**.

3.3 الرئيس + الأمانة العامة — ai / ai_committee (اللجنة الوطنية)

Who: national oversight over the approved portfolio.

Pages (sidebar): - **الرئيسية** — national KPI boxes (إجمالي المدخلات، القابلة للتحويل، المستهدف تحويلها، غير قابلة للتحويل) and the three stream cards, each with **قوائم الحصر** — **الجهات المشاركة** — the three streams' approved entries (read-only) - **دفعات الإطلاق** — one sub-page per stream (read-only)

Cannot: create, edit, approve or return anything.

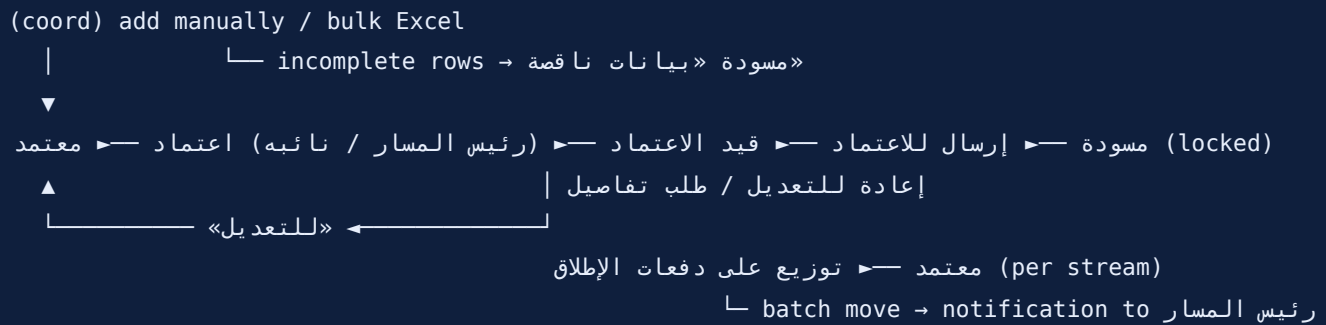
3.4 مشرف النظام — admin / system_admin

Who: IT / platform administration. Bypasses permission checks server-side; every action is still audit-logged.

Pages: the admin console instead of the dashboards — plus «لوحات المتابعة» to open the monitoring dashboards — **المستخدمون** — create/edit/enable/disable users for **all entities**; **المسار** require **رئيس المسار / نائب رئيس المسار / منسق المسار في الجهة** (الدور); the coordinator also requires **الجهة**; bulk upload from the Excel template - **رؤساء المسارات واللجنة** — assign the three stream heads and committee - **الأدوار والصلاحيات** — role reference - **الموقع العام** — edits everything on the public site: **من نحن** (hero, timeline with milestone photos, targets, tracks, scope, principles) and **المنشورات** (documents with cover + PDF attachments) - **التواصل والاستفسارات** — the public contact inbox

In production the full management surface is the **admin API suite** (`/api/admin/users|roles|role-rules|entities|streams|audit-logs`), plus `BOOTSTRAP_ADMIN_EMAILS` for the very first sign-in.

4. The workflow and who acts at each step



- Drafts (wf = draft): visible to the coordinator only.
- قيد الاعتماد (ent1): coordinator + stream head/deputy.
- معتمد (exec onwards): locked; visible to the committee's national view.
- Every server-side action lands in log_entries (business trail shown in السجل) and audit_logs (security trail with actor/IP/user-agent).
- Mandatory automatic emails (wired by IT via POST /api/notify): submission → stream head + deputy; approval/return/info request → coordinator; batch move → stream head.

5. Backend permission matrix (seeded — prisma/seed.ts)

Permission	coord	stream head/deputy	committee	admin
items:view / export	✓	✓	✓	✓
items:create / update / submit	✓	—	—	✓
items:approve / reject	—	✓ (the ent1 gate)	✓ ¹	✓
reports:view	✓	✓	✓	✓
reports:export	—	—	✓	✓
ai_review:run	—	—	✓	✓
users / roles / audit / settings	—	—	—	✓

¹ Committee approval permissions exist for future gates; in the current flow the committee is read-only and the ent1 approval is performed by the stream head or deputy.

Extra backend-only roles (no dedicated UI — they land on the closest read-only view): `program_admin` (مدير البرنامج) — everything except `settings:*` · `viewer` (مستعرض) — read-only within scopes · `auditor` (مدقق) — read-only + `audit:view` · `entity_representative` / `entity_admin` — legacy, view-level only.

6. Where this is enforced in code

Concern	File
Permission + scope checks per request	<code>lib/security/rbac.ts</code> (<code>assertPermission</code> , <code>assertItemAccess</code>)
Session → user + roles + scopes	<code>lib/security/auth.ts</code> , <code>/api/auth/me</code>
Role/permission/scope tables	<code>prisma/schema.prisma</code> (migrations <code>0007</code> – <code>0010</code>)
Seeded matrix + starter accounts	<code>prisma/seed.ts</code>
Entity-scoped services catalog	<code>app/api/svc-catalog/route.ts</code> , <code>lib/svcCatalog.ts</code>
Page/menu/filter scoping (UX)	<code>lib/viewModel.ts</code>
Identity → user mapping on login	<code>lib/security/user-access.ts</code>